

WEEK 1: VULNERABILITY ASSESSMENT FINDINGS

CRITICAL & HIGH RISK VULNERABILITIES

- **SQL Injection (Auth Bypass):** Successfully bypassed Admin login using ' OR 1=1 -- to manipulate database logic.
- **Reflected XSS:** Confirmed script execution via `<iframe src="javascript:alert(1)">` in search/profile fields.
- **Broken Access Control:** Gained unauthorized access to confidential documents and administrative scoreboards.

MEDIUM RISK (CONFIGURATIONS)

- **CSP Header Missing:** No Content Security Policy defined, increasing the risk of data injection.
- **Anti-Clickjacking Missing:** X-Frame-Options header not set, leaving the site open to UI redressing.
- **Vulnerable JS Libraries:** Use of outdated libraries (jQuery 3.3.1, Bootstrap 3.3.7) with known CVEs.

LOW & INFORMATIONAL RISK

- **Cookie Misconfiguration:** Cookies lack HttpOnly and SameSite attributes, enabling CSRF and session theft.
- **Server Fingerprinting:** HTTP headers leak Express and Server version information.
- **Source Code Comments:** Developer comments leak internal logic and technical details.

AREAS OF IMPROVEMENT

- **Input Sanitization:** Implement the validator library for all user inputs.

- **Security Headers:** Utilize `Helmet.js` to enforce CSP, HSTS, and Frame protection.
- **Password Hashing:** Migrate plain-text storage to salted hashes using `bcrypt`.
- **Cookie Hardening:** Set `SameSite: Strict` and `HttpOnly` flags for all session tokens.
- **Information Concealment:** Suppress version headers and purge developer comments.